

Implement Least-Privilege IAM

75 minutes · Mapped criteria A1, K1

Purpose and work product

Create a workload service account, grant a narrow role and verify both allowed and denied actions.

Submit: iam-policy-before.json, iam-policy-after.json and access-test.txt

Safety, cost and privacy

Use only the assigned training project. Confirm the active account, project and region before every mutation. Never place credentials, payment details, access tokens or private keys in screenshots or submitted files. Stop billable resources and verify the final inventory.

Files in this folder

File	Purpose
iam_setup.sh	Mock data, script or configuration used by this activity

Detailed procedure

Step 1

Set PROJECT_ID and save the current project IAM policy as iam-policy-before.json.

Step 2

Create the user-managed service account app-runtime using the supplied script.

Step 3

Grant only roles/storage.objectViewer at project scope. Do not grant Owner or Editor.

Step 4

Save the new policy as iam-policy-after.json and compare the two files.

Step 5

Use IAM Policy Troubleshooter or a dry-run access test to check that the service account can read object metadata.

Step 6

Attempt a storage object delete with the service account. Record the expected permission-denied result.

Step 7

Inspect Cloud Audit Logs for the SetIamPolicy call and record principalEmail, methodName and resourceName.

Step 8

Remove any temporary human test binding. Keep the service account for Activities 4 and 7.

Verification record

Record expected and observed output. A successful command without the correct project, identity, scope or evidence is not an accepted result.

Check	Expected evidence
Identity and scope	Active account, project ID, region or zone
Configuration	Resource description or policy output
Runtime result	Test output with UTC timestamp
Failure test	One controlled negative test and diagnosis
Cleanup	Final inventory and stopped/deleted billable resources

Troubleshooting sequence

Check the active identity and project first, then API enablement and IAM, then resource state, networking and quotas. Preserve the failed output before making a correction. If the issue remains, escalate with the exact command, timestamp, expected result, observed result and evidence files.

Cleanup

Delete or stop resources as instructed. Re-open Billing and the relevant service inventory, then record the remaining resource names. Budget alerts do not stop charges.